

Security Design

API Key Management

The Anthropic API key is the only secret the pipeline requires. It is loaded exclusively from the `ANTHROPIC_API_KEY` environment variable using `os.environ["ANTHROPIC_API_KEY"]` - not `os.getenv()`, which returns `None` silently. The `os.environ` access occurs at module import time in `src/config.py`, causing the process to exit immediately with a `KeyError` if the key is absent. This fail-loud pattern prevents the pipeline from running in a degraded state where LLM calls would silently fail after expensive data processing has completed.

The API key is passed as a parameter to `llm_engine.enrich_with_llm()` and is never stored beyond that function's stack frame. It is never written to any output file, never included in any log statement, never embedded in prompt text sent to the API, and never stored in the `run_log` dictionary. The `run_log` is explicitly audited to contain exactly seven safe keys: `run_timestamp`, `students_processed`, `api_calls_made`, `tokens_used`, `errors_encountered`, `fallbacks_triggered`, and `data_quality_warnings`.

The `.env` file that holds the key in development is listed in `.gitignore` and is never committed to version control. The `.env.example` file in the repository contains a placeholder value ("your-anthropic-api-key-here") and no real key. Developers are instructed to copy `.env.example` to `.env` and populate it locally. In production deployment, the environment variable should be injected by the host operating system or a secrets manager rather than stored in any file.

PII Handling

Student personally identifiable information includes student names, campus IDs, and parent phone numbers. These fields are present in the source CSVs and the merged `DataFrame`, and they flow into the output Excel files and WhatsApp CSV that are the pipeline's primary deliverables. The pipeline cannot mask this data in outputs because the facilitator needs it to contact families - the PII is the point of the output.

However, PII is masked in log statements. The `llm_engine.py` module logs only aggregate counts (number of students per campus, total tokens) at INFO level. Individual student names and phone numbers never appear in log output at any level. This means that even if log files are shipped to a centralised logging service, they contain no student-identifiable data. The `run_log.json` file similarly contains only aggregate statistics, not per-student records.

Student data is sent to the Anthropic API in the cohort prompt, but only in the form of anonymised engagement metrics (attendance rate, practice question count, trend direction, days since last note). Student names and phone numbers are not included in the API prompt. The API receives performance data attributed to a campus cohort label (e.g., "Campus C01"), not to named individuals.

Data Retention

The `outputs/` directory produced by a pipeline run contains PII: student names, campus IDs,

parent phone numbers, and AI-drafted WhatsApp messages addressed to specific families. This directory should be treated as a sensitive document and should not be retained beyond the facilitator's review session. The recommended practice is to delete the outputs/ directory at the end of each working day after the facilitator has acted on the intervention list.

Student data should not be persisted in any intermediate format between runs. The pipeline is designed as a stateless daily batch: it reads from source CSVs, produces output files, and terminates. There is no database, no session state, and no cache. Each run is independent. If a run fails midway, the partial outputs/ directory should be deleted and the run restarted from scratch rather than attempting to resume from intermediate files.

If outputs need to be retained for audit or reporting purposes, they should be stored in an access-controlled location (e.g., a SharePoint folder with facilitator-role access only, or a server directory with Unix file permissions set to 640 or stricter). The default outputs/ directory in the project folder has no access control and should not be used for long-term retention.

Access Control

The pipeline is designed for single-machine execution by one authorised operator per campus. There is no authentication server, no user login, and no role-based access control layer in the software itself. Access control is delegated to the operating system: the project directory, the .env file, and the outputs/ directory should have their read permissions restricted to the facilitator user account on the machine where the pipeline runs.

On Windows, this means setting folder permissions via Properties > Security to allow only the facilitator account (and Administrators). On Linux/macOS, `chmod 700` on the project directory and `chmod 600` on the .env file are the appropriate settings. The outputs/ directory should be set to `chmod 700` or equivalent.

If the pipeline is deployed on a shared machine (e.g., a school server accessed by multiple staff), a dedicated service account should be created for the pipeline process, and the .env file and outputs/ directory should be owned by that account with no world-read permissions. In a multi-campus deployment, each campus should run its own isolated pipeline instance rather than sharing a single instance with a combined student dataset.